



NETWORK SECURITY | MODULE 2

Security Attacks and Security Services

Lesson 3 – Types of Attacks

Lesson 9 – Attacks, Services and the Security Model



Criminal · Passive · Active · Viruses · Cryptanalytic attacks · Security services · Security model



LESSON 3: TYPES OF ATTACKS

1

The Common Person's View

Criminal, publicity and legal attacks

2

The Technologist's View

Passive and active attacks

3

Attacks in Practice

Application-level and network-level attacks

4

Programs That Attack

Viruses: phases and types

5

Attacks on Ciphers

Key sizes and five cryptanalytic attacks

LESSON 9: ATTACKS, SERVICES, MODEL

6

Active Attacks Revisited

Masquerade, replay, modification, DoS

7

Security Services

Six services that fight attacks

8

A Model for Network Security

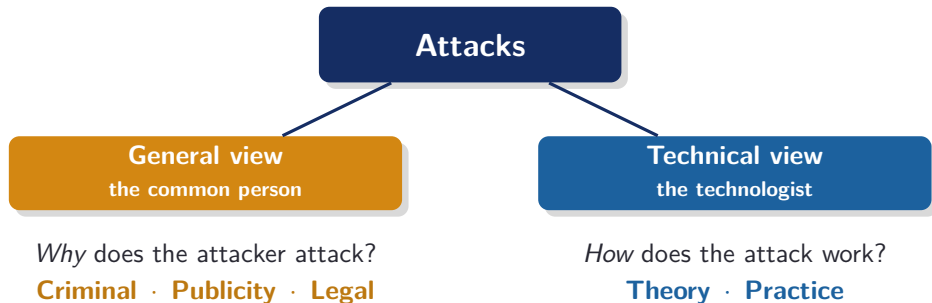
Four design tasks and the access model



Lesson 3

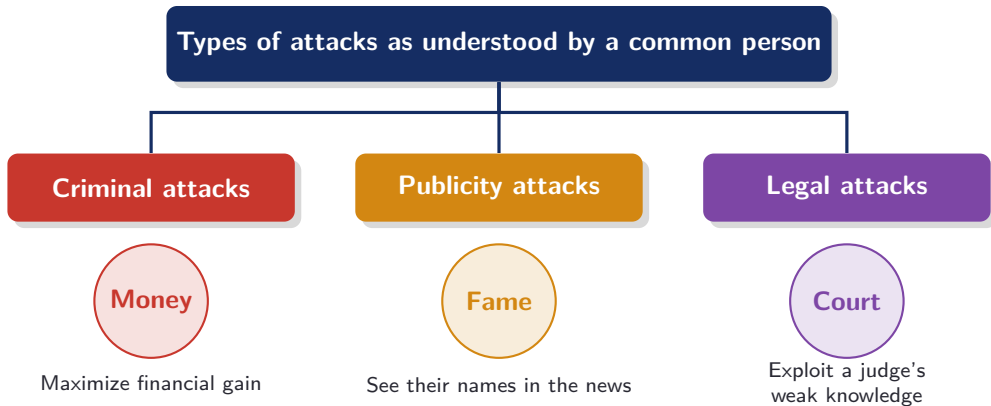
Types of Attacks

Two Ways to Look at Attacks



Why two views?

A bank manager worries about *fraud*; a network engineer worries about *packet modification*. Both describe the same threat, from different angles.





Fraud

Manipulating e-currency, credit cards, cheques, ATMs

Scams

Fake sales, auctions, “get rich” schemes (Nigeria e-mail scam)

Destruction

Grudge attacks by unhappy employees or terrorists (Yahoo!, CNN, eBay in 2000)

Identity theft

Becoming a legitimate user: stolen bank passwords, cards in someone’s name

IP theft

Stealing trade secrets, databases, music, videos, software

Brand theft

Fake look-alike web sites that collect users’ secrets

Goal

The only aim is to **maximize financial gain**.

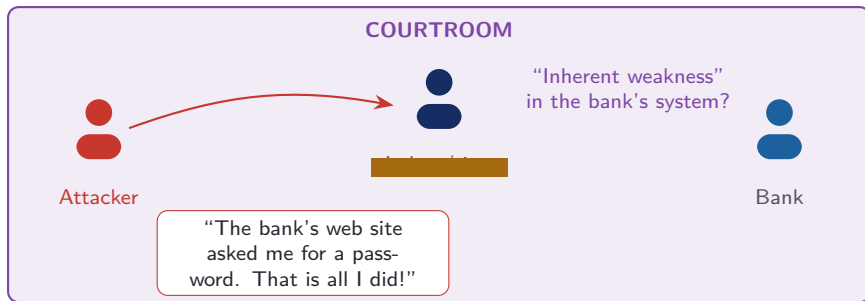


“Look at me!”

- Attackers want to see their **names on TV and in newspapers**
- Usually **not hardcore criminals**: often students or employees seeking publicity with a novel attack
- Common form: **defacing web pages**

Famous cases

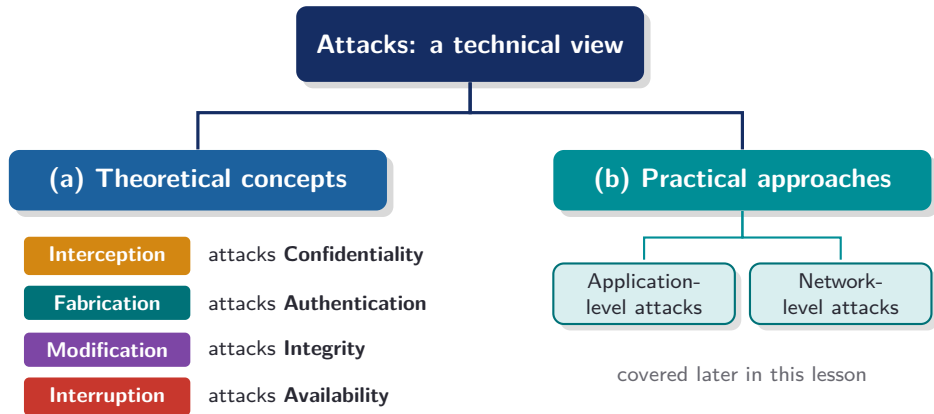
- US Department of Justice web site (1996)
- *The New York Times* home page (two years later)

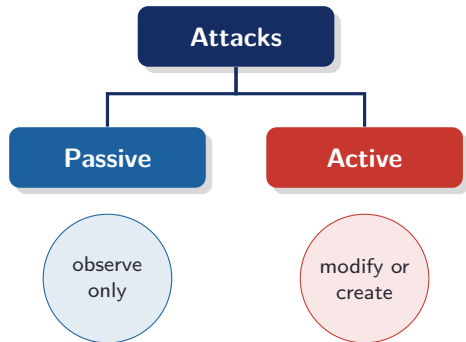


- A **novel and unique** form of attack
- The attacker makes the judge doubt the **security of a computer system**

The trick

Exploit the weak technology knowledge of the **judge and jury**, who are likely to sympathize with the attacker.





Passive attacks

The intruder **observes** the message or transmission but does **not modify** it. The aim is to **obtain information**.

Active attacks

The **contents of the original message are modified** in some way, or a false message is created.

Interception is **passive**; interruption, modification and fabrication are **active**.

Passive Attack 1: Release of Message Contents



Passive attacks (interception)

Release of
message contents

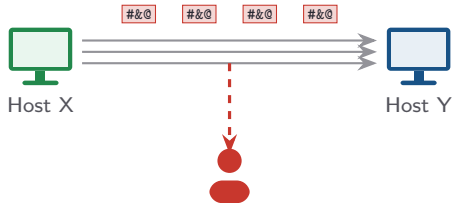
Traffic analysis

- We send a **confidential e-mail**: only our friend should read it
- If someone else reads it, its contents are **released against our wishes**
- Also: phone calls, transferred files with sensitive data

Defence

Encode the message in a code language (encryption) that only the two parties understand.

Passive Attack 2: Traffic Analysis



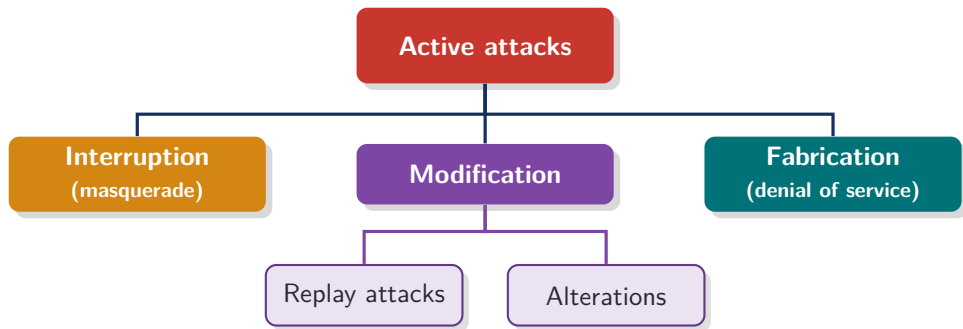
Eve notes:

- who talks to whom ($X \leftrightarrow Y$)
- how often, how long, what size
- at what time of day

- Intercepting and examining messages to **deduce information from patterns**
- Works **even when messages are encrypted** and cannot be read
- The more messages observed, the more can be inferred
- Reveals the **location and identity** of communicating hosts

Example

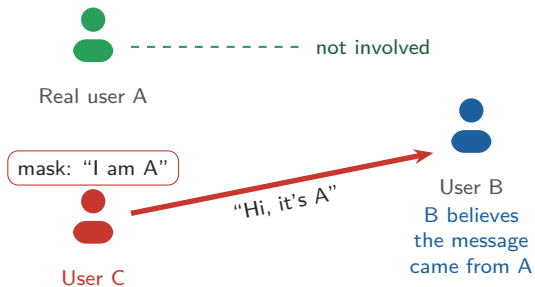
A sudden burst of traffic between two companies may reveal a secret merger.



- Posing as another entity: **masquerade**
- Modification: **replay** and **alteration** of messages

- Fabrication: **denial of service (DoS)**
- Cannot be **prevented** easily, but can be **detected** and recovered from

Active Attack: Masquerade



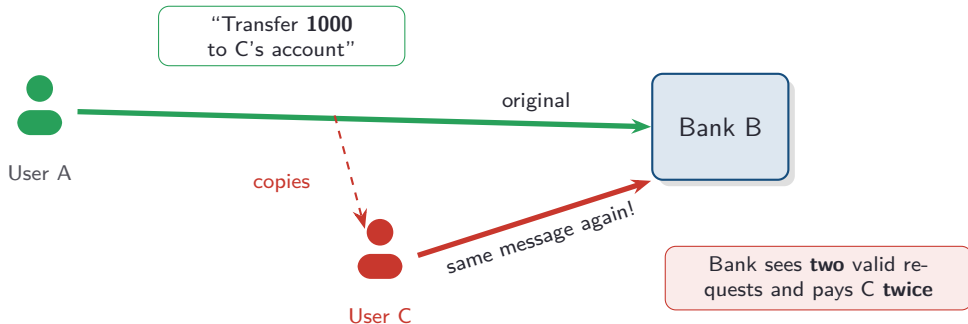
Definition

An **unauthorized entity pretends to be another entity.**

- User C sends a message to B posing as user A
- Often combined with other active attacks
- E.g. capture A's **user ID and password**, then replay them later to gain illegal access



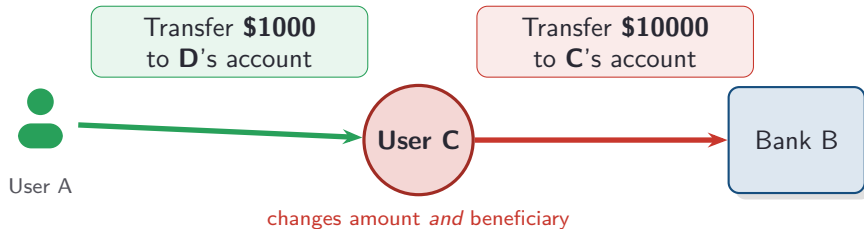
Active Attack: Replay



Definition

A user **captures a sequence of events or data units and re-sends them**. The bank cannot tell the copy from a second, genuine request.

Active Attack: Alteration of Messages



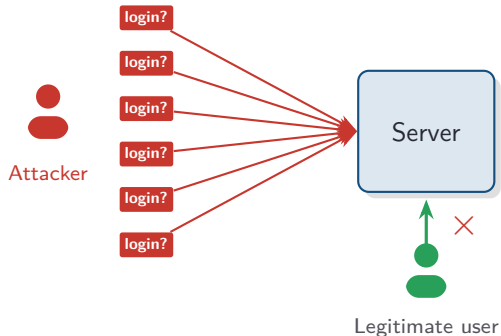
Definition

Some change is made to the **original message** while it is in transit.

Note

Here both the beneficiary and the amount changed; changing **either one alone** would also be an alteration.

Active Attack: Denial of Service (DoS)



Definition

An attempt to **prevent legitimate users** from accessing services they are eligible for.

Example

- Send **too many login requests** with random user IDs in quick succession
- The network is **flooded**
- Legitimate users are denied the facilities

Threatens: **availability**



Security attacks in practice

Application-level attacks

Access, modify or block the information of a **particular application**.

e.g. steal a credit card number from the Internet; change the amount in a transaction

Network-level attacks

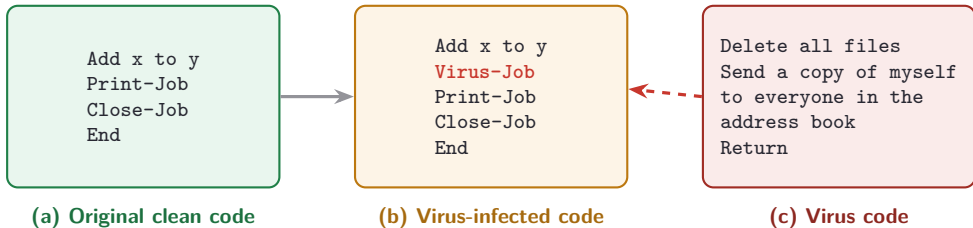
Reduce the **capabilities of a network**: slow it down or bring it to a halt.

Can **lead to** application-level attacks once the attacker is inside the network

Key sentence

Security attacks can happen at the **application level** or at the **network level**, using many mechanisms.

Programs That Attack: The Virus

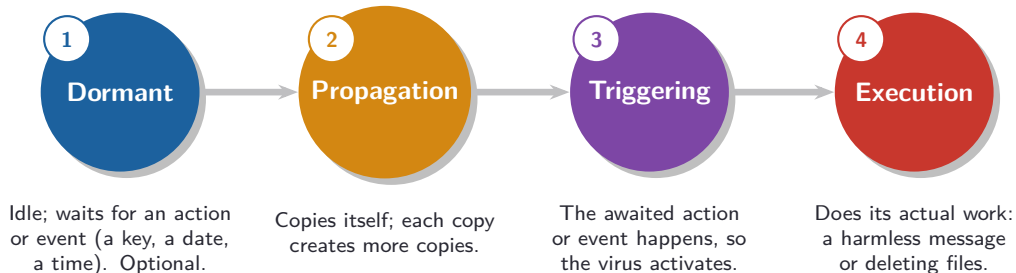


Definition

A computer program that **attaches itself to another legitimate program** and causes damage to the computer system or network.

- Runs whenever the host program runs
- Can infect other programs on the same computer or network
- Can be triggered by events (e.g. 12 PM every day)

The Four Phases of a Virus



Good news

Usually the damage can be repaired, provided the organization keeps **good backup and recovery** procedures.

Types of Viruses



Parasitic

Most common. Attaches to executable files and spreads when they run.

Memory-resident

Lodges in main memory, then infects every program that runs.

Boot sector

Infects the master boot record; spreads when the OS boots.

Stealth

Has built-in intelligence to hide from anti-virus software.

Polymorphic

Changes its signature (identity) on every execution.

Metamorphic

Changes its signature **and** rewrites itself every time.

harder and harder to detect



Key size = 40 bits

```
00 00 00 00 00
00 00 00 00 00 + 1
...
FF FF FF FF FF
```

Key size = 64 bits

```
00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 + 1
...
FF FF FF FF FF FF FF FF
```

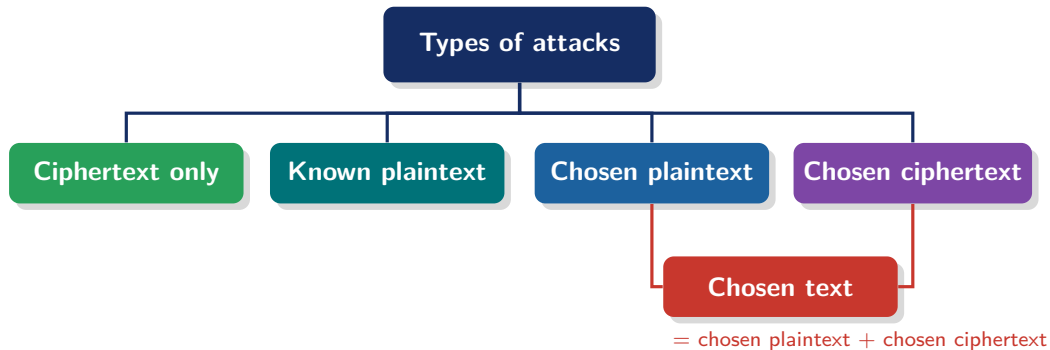
Key size = 128 bits

```
00 00 ... 00 00 (16 bytes)
00 00 ... 00 00 (16 bytes) + 1
...
FF FF ... FF FF (16 bytes)
```

- Keys can be written in **hexadecimal**
- Bigger key $\Rightarrow$ bigger range $\Rightarrow$ more work for the attacker
- $2^{128} \approx 3.4 \times 10^{38}$ possible keys
- 56-bit keys are no longer safe; 128-bit is safe *today*

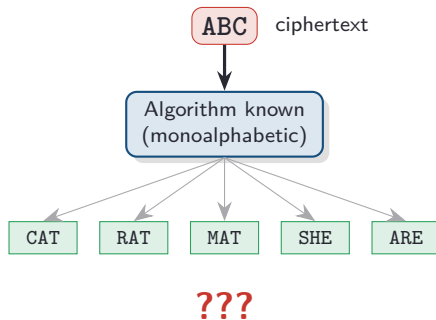
Will 512 bits ever break?

Even if every atom in the universe (2^{300}) were a computer checking 2^{300} keys/s, searching 1% of a 512-bit space would take 2^{162} millennia. The universe is younger than 2^{34} millennia!



The setting

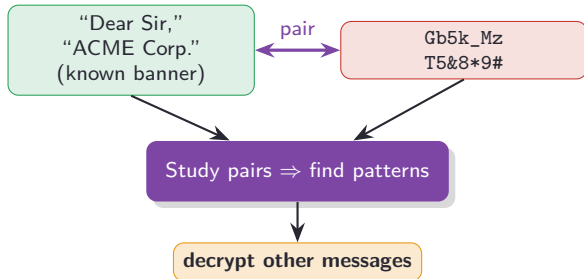
The sender encrypts a plaintext message into ciphertext. The attacker's goal is to find the **plaintext** or, better, the **key**. What the attacker already knows decides which of these **five** attacks is possible.



- The attacker has **only ciphertext** and no clue about the plaintext
- Analyses it using **letter frequencies** (e, i, a are common in English)
- **More ciphertext** means better chances

Confusion for the attacker

A short block like ABC could be CAT, RAT, MAT, SHE, ARE...: far too many possibilities.



- The attacker knows some **plaintext–ciphertext pairs**
- Uses them to find **more pairs** and more plaintext
- Examples: company banners, file headers, standard greetings

How does the attacker get plaintext?

Old plaintext may become **outdated and public**, or be **leaked** inadvertently.

Chosen-Plaintext Attack: The Telegraph Story

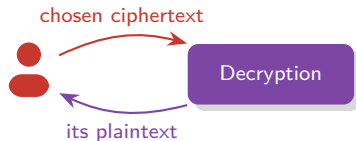


Definition

The attacker **selects a plaintext block** and obtains its ciphertext, deliberately picking patterns that reveal more about the key.

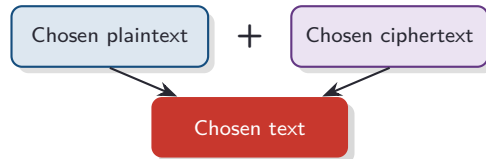
- A telegraph company encrypts people's messages for them
- The attacker simply **pays** to send a chosen text
- Now they own a matching plaintext–ciphertext pair

Chosen-Ciphertext and Chosen-Text Attacks



Chosen ciphertext

The attacker knows the ciphertext to be decrypted, the **algorithm**, and the corresponding plaintext block. The job: **discover the key**. Not very common.



Chosen text

Essentially a **combination** of the chosen-plaintext and chosen-ciphertext attacks.

Summary of Attacks on Ciphers



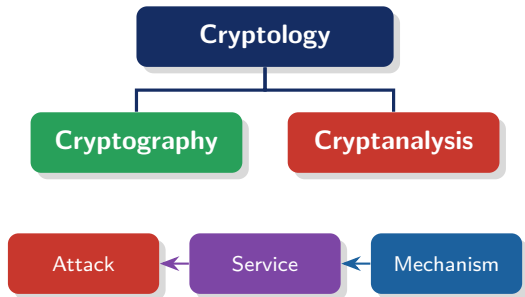
Attack	Things known to the attacker	Things the attacker wants
Ciphertext only	Ciphertext of several messages (same key); algorithm	Plaintext of those messages; the key
Known plaintext	Ciphertext of several messages; some matching plaintext; algorithm	Algorithm to decrypt; the key
Chosen plaintext	Ciphertext and plaintext; chooses the plaintext to encrypt	The key; decryption of other ciphertext
Chosen ciphertext	Ciphertext of messages to be decrypted; matching plaintext	The key used for encryption
Chosen text	Some of the above	Some of the above

Reading down the table, the attacker **knows more**, so the attack becomes **more powerful**.



Lesson 9

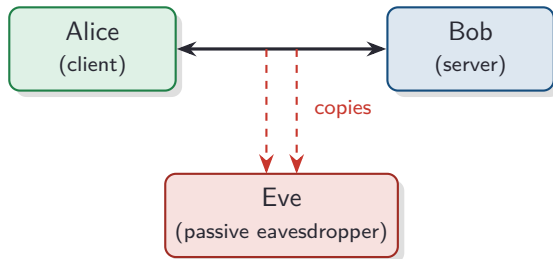
Cryptography: Attacks, Services and the Security Model



- **Cryptography**: designing systems to code and decode messages
- **Cryptanalysis**: breaking them without the key
- **Attack**: compromises security
- **Mechanism**: detects, prevents or recovers (encryption, digital signature, SSL)
- **Service**: enhances security, using one or more mechanisms

Lesson 9 now looks deeper at attacks, services and a **model** that ties them together.

Passive Attack: Eve Listens to Alice and Bob



- An unauthorized attacker **monitors or listens** to the communication
- The goal is to **obtain information**
- Two kinds: **release of message contents** and **traffic analysis**

Hard to detect, easy to prevent

No data is altered, so passive attacks are very **difficult to detect**; but encryption makes them feasible to **prevent**.

Active Attacks: The Four Categories



Masquerade

Pretend to be an authorized user to gain access or greater privileges

Replay

A valid transmission is maliciously repeated or delayed

Modification of messages

Part of a legitimate message is altered, delayed or reordered

Denial of service

Prevents or inhibits normal use or management of communication

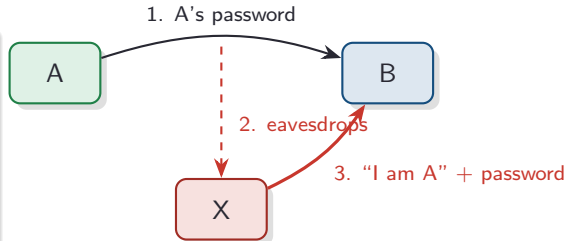
Common feature

Active attacks involve some **modification of the data stream** or the **creation of a false stream**.



Masquerade

- Uses **stolen logon IDs and passwords**, security gaps, or bypasses authentication
- May come from **inside** the organization or from outside
- **Weak authentication** is the easiest entry point
- Once in, the attacker may modify or delete data and change network configuration



Replay

X keeps A's password from the last session and sends it to B later. B **must accept** it.



Modification of messages

A message is altered, **delayed or reordered** to produce an unauthorized effect.

“Allow **John Smith** to read confidential file *accounts*”



modified

“Allow **Fred Brown** to read confidential file *accounts*”

Denial of service

Prevents or inhibits the normal use or management of communication facilities.

Specific target: suppress all messages to one destination (e.g. the security audit service)

Whole network: disable it, or overload it with messages to degrade performance

Passive vs. Active: What Should We Do?



Passive attacks

Very difficult

Detect?

Active attacks

Possible

Feasible

Prevent?

Very difficult

Prevention (encryption)

Strategy

Detection and recovery

No data is altered

Why?

Too many physical, software, network weaknesses

Bonus

If detection has a **deterrent effect**, it also contributes to preventing active attacks.



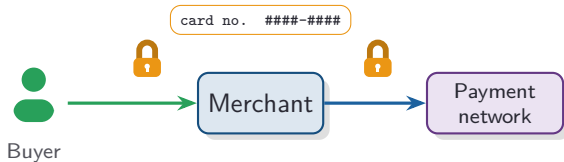
What is a security service?

A **base-level service** used to combat security attacks.

Do not confuse

Services are **not** mechanisms. Mechanisms are the **actual implementations** of these services.

The next slides take each service in turn.



Encrypt the card number in transit; limit where it is stored (databases, logs, backups, receipts)

- Provides **secrecy**: only authorized users can access information
- Works with **accountability** to identify individuals
- Protects data in **paper files, electronic files, and in transit**

Breaches of confidentiality

Someone reading your screen over your shoulder · a stolen laptop with employee data · giving information over the phone to an unauthorized caller



Password

Something you know; can be stolen, revealed or forgotten

Digital certificate

Issued and verified by a Certificate Authority (CA) in a PKI

stronger,
future
standard

Definition

Establishing or confirming that something (or someone) is **authentic**: claims made about it are true.

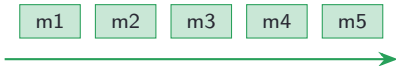
- Confirms the identity of a **person**, the origin of an **artifact**, or that a **program** is trusted
- Commonly done with **logon passwords**
- Money transactions need a **more stringent** process



Definition

The assurance that information can only be **accessed or modified by those authorized** to do so.

Connection-oriented integrity

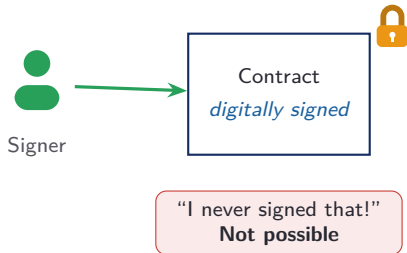


A **stream** of messages is received as sent: no duplication, insertion, modification, reordering or replay. Also covers **destruction** of data.

Connectionless integrity



Handles **individual messages** with no regard to larger context. Protects against **message modification only**.



Definition

A party to a contract or communication **cannot deny** the authenticity of its signature or of sending a message it originated.

- A **digital signature** proves who signed, and can be created by **only one person**
- No technology is fool-proof, so add **biometrics**, time stamps, printed receipts



Access control

The ability to **permit or deny** the use of a resource by a particular entity.

Physical

Movie theatre: ticket holders only

Logical

Bank account: limited people may withdraw

Digital

Private file: only some users may read

Availability

A system or resource is **accessible and usable on demand** by an authorized entity, per its specifications.

- Network, hardware and software are **reliable**
- They **recover quickly** after an interruption
- They should resist **denial-of-service** attacks

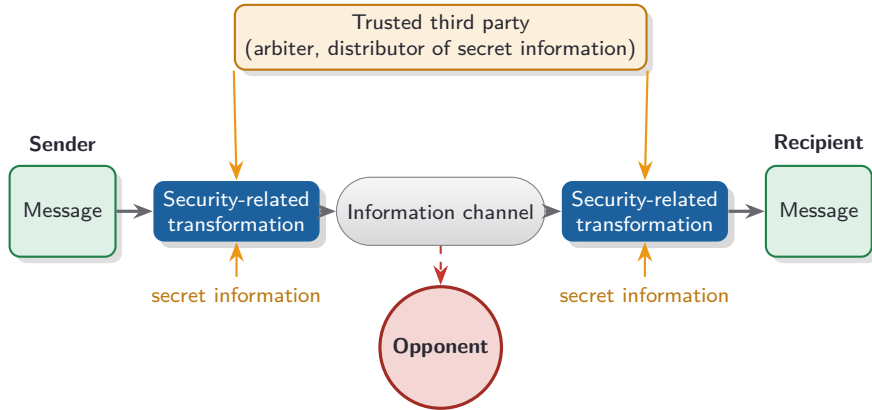
Which Service Fights Which Attack?



	Confid.	Auth.	Integrity	Non-rep.	Access	Avail.
Release of contents	✓				✓	
Traffic analysis	✓					
Masquerade		✓			✓	
Replay		✓	✓			
Modification			✓	✓		
Denial of service						✓

Every attack is answered by at least one service, and each service is built from mechanisms (Modules 6–12).

A Model for Network Security



- Two **principals** cooperate over a logical channel (a route through the Internet using protocols such as TCP/IP)
- Security = a **transformation** of the message (e.g. encryption) + **secret information** shared by the two (e.g. a key)

Four Basic Tasks in Designing a Security Service



1

Design an **algorithm** for the security-related transformation that an opponent cannot defeat

2

Generate the **secret information** to be used with the algorithm

3

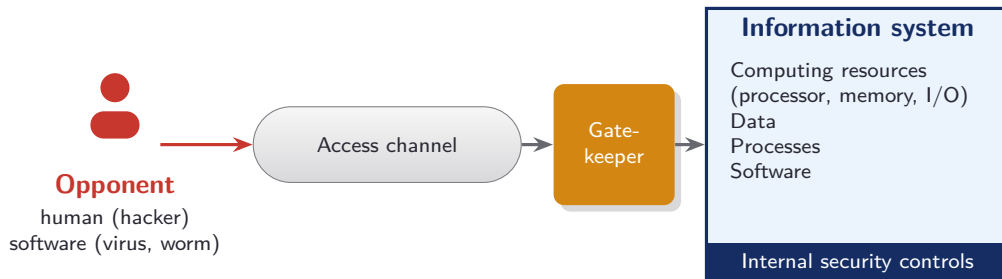
Develop methods to **distribute and share** the secret information

4

Specify a **protocol** that uses the algorithm and secret information to achieve the service

A **trusted third party** may distribute the secret information or settle disputes between the principals.

The Network Access Security Model



- Protects an information system from **unwanted access**
- **Gatekeeper function**: password logins, screening programs; then **internal controls** watch activity inside



Intruders



Hacker

Enjoys breaking in; no malign intent



Disgruntled employee

Wants to do damage



Criminal

Seeks financial gain: card numbers, illegal transfers

Malicious logic

Logic placed in a system to exploit vulnerabilities; it can affect applications and utility programs (editors, compilers).

Information access threats:
intercept or modify data for users who should not access it

Service threats: exploit service flaws to stop legitimate users



Lesson 3: Types of Attacks

- General view: criminal, publicity, legal
- Technical view: passive vs. active
- Masquerade, replay, alteration, DoS
- Application- vs. network-level attacks
- Viruses: 4 phases, 6 types
- 5 attacks on ciphers

Lesson 9: Attacks, Services, Model

- Passive: release of contents, traffic analysis
- Active: masquerade, replay, modification, DoS
- Six security services
- Model for network security; 4 tasks
- Network access security model

Review questions

1. Explain different types of attacks.
2. What are the possible types of attacks (on a cipher)?
3. Write short notes on different types of security attacks.
4. Explain the model for network security.
5. What are the different types of security services?



- ① William Stallings, *Cryptography and Network Security*, PHI Publishers.
- ② Charlie Kaufman, Radia Perlman, *Network Security*, Pearson Education.
- ③ Bruce Schneier, *Applied Cryptography*, John Wiley & Sons.
- ④ Roberta Bragg, *Network Security: The Complete Reference*, TMH.

Thank You! Questions?